

Security+ 2.3 · Cloud-specific Vulnerabilities

Mestre CyberSec — PDF baseado na aula do Professor Messer · 2.3 — Cloud-specific Vulnerabilities (4:06)

· [vídeo original ↗](#) · [YouTube ↗](#)

Ataques da nuvem: DoS com FATURA (gera custo alto — o atacante não derruba o serviço, só deixa caro); authentication bypass (API aberta/exploit); directory traversal (acessar arquivo fora do permitido). O maior risco NUVEM: MISCONFIGURAÇÃO (bucket aberto, IAM permissivo). Responsabilidade compartilhada: provider cuida DA nuvem; cliente cuida NA nuvem.

Highlights que a prova cobra

- Bucket S3 aberto = o vazamento nº1 de cloud
- Respons. compartilhada: provider = DA nuvem; cliente = NA nuvem
- Defesa: CSPM (checa config), IAM com menor privilégio

Dicas de prova

- 'misconfigured bucket exposes data' = cloud misconfig (a falha nº1)
- 'client is responsible for securing data IN the cloud' = shared responsibility

Cenário clássico: Cenário: 'empresa armazena dado de cliente num bucket S3 público por erro de config' = misconfiguration (a falha mais comum em cloud).

Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. No modelo de RESPONSABILIDADE COMPARTILHADA, quem cuida da segurança FÍSICA do datacenter?

- A)** O cliente
- B)** O provedor de nuvem
- C)** Os dois igualmente
- D)** Um auditor externo

2. No modelo de responsabilidade compartilhada AWS, o cliente NÃO é responsável por:

- A)** Criptografia de dados
- B)** Patches do hypervisor
- C)** Configuração de security groups
- D)** Gerenciamento de identidades

3. Proteger dados 'em repouso' (at rest) significa criptografar:

- A)** O tráfego na rede
- B)** Os dados gravados no storage/disco
- C)** A senha do usuário
- D)** O código-fonte

4. O serviço que controla QUEM pode acessar O QUÊ na nuvem (usuários, papéis, permissões) é o:

- A)** CDN
- B)** IAM
- C)** VPN
- D)** DNS

5. Cenário corporativo (Cloud-specific Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Bucket S3 aberto = o vazamento nº1 de cloud'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Bucket S3 aberto = o vazamento nº1 de cloud...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Cloud-specific Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Respons. compartilhada: provider = DA nuvem; cliente = NA nuvem'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Respons. compartilhada: provider = DA nuvem; cliente = NA nuvem...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Cloud-specific Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Defesa: CSPM (checa config), IAM com menor privilégio'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Defesa: CSPM (checa config), IAM com menor privilégio...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Cloud-specific Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: '"misconfigured bucket exposes data' = cloud misconfig (a falha nº1)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'misconfigured bucket exposes data' = cloud misconfig (a falha nº1)...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Cloud-specific Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: '"client is responsible for securing data IN the cloud' = shared responsibility'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'client is responsible for securing data IN the cloud' = shared responsibil...

10. Cenário corporativo (Cloud-specific Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Cenário: 'empresa armazena dado de cliente num bucket S3 público por erro de config' = misconfiguration (a falha mais comum em cloud)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Cenário: 'empresa armazena dado de cliente num bucket S3 público por erro d...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

- 1) B — O provedor de nuvem.** O provedor cuida da segurança DA nuvem (hardware, datacenter, rede física). O cliente cuida da segurança NA nuvem (seus dados, acessos/IAM, configs). Config errada = culpa do cliente.
- 2) B — Patches do hypervisor.** AWS gerencia a infraestrutura física e hypervisores; cliente gerencia OS, dados, IAM e configurações.
- 3) B — Os dados gravados no storage/disco.** Em repouso = dado parado no disco/banco (criptografia at rest). 'Em trânsito' = dado viajando na rede (TLS). Boa prática cobre os dois.
- 4) B — IAM.** IAM (Identity and Access Management) gerencia identidades e permissões. É onde você aplica menor privilégio na nuvem. CDN acelera conteúdo; DNS resolve nomes.
- 5) B — Implementar a solução correspondente: Bucket S3 aberto = o vazamento nº1 de clou.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cloud-specific Vulnerabilities): Bucket S3 aberto = o vazamento nº1 de cloud. As demais alternativas configuram violações graves de con
- 6) A — Implementar a solução correspondente: Respons. compartilhada: provider = DA nuve.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cloud-specific Vulnerabilities): Respons. compartilhada: provider = DA nuvem; cliente = NA nuvem. As demais alternativas configuram vio
- 7) C — Implementar a solução correspondente: Defesa: CSPM (checa config), IAM com menor.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cloud-specific Vulnerabilities): Defesa: CSPM (checa config), IAM com menor privilégio. As demais alternativas configuram violações gra
- 8) C — Implementar a solução correspondente: 'misconfigured bucket exposes data' = clou.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cloud-specific Vulnerabilities): 'misconfigured bucket exposes data' = cloud misconfig (a falha nº1). As demais alternativas configuram
- 9) D — Implementar a solução correspondente: 'client is responsible for securing data I.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cloud-specific Vulnerabilities): 'client is responsible for securing data IN the cloud' = shared responsibility. As demais alternativas
- 10) C — Implementar a solução correspondente: Cenário: 'empresa armazena dado de cliente.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Cloud-specific Vulnerabilities): Cenário: 'empresa armazena dado de cliente num bucket S3 público por erro de config' = misconfiguratio